BIL 481 Software Engineering - Project Assignment 1

Proje Adı: Yazılım Tedarik Zinciri Risk Tarayıcısı (yztr) / Software Supply Chain Risk Scanner

Grup Adı: CodeShield

2. Requirements Document

Yazarlar (Authorship): Ömer Ali Sarıcalar, Yusuf Emir Coşar

İçindekiler (Table of Contents)

1. Fonksiyonel Gereksinimler (Functional Requirements)
2. Fonksiyonel Olmayan Gereksinimler (Non-Functional Requirements)
3. Dokümana Özel Görev Matrisi (Document-Specific Task Matrix)

2.1 Fonksiyonel Gereksinimler (FR)

1. **FR-1.1:** Sistem; npm package-lock.json (v2/v3), PyPI poetry.lock ile uv.lock, sürümü sabitlenmiş requirements.txt ve CycloneDX SBOM dosyalarını girdi olarak okuyabilmelidir.
2. **FR-1.2:** Sistem; requirements.txt içinde sürümü sabitlenmemiş (unpinned) bir satır algıladığında uyarı (warning) vermelidir.
3. **FR-2.1:** Sistem; Git komutları (git show) aracılığıyla çalışma ağacını (working tree) değiştirmeden "base" ve "head" referansları arasındaki farklı paketleri "eklenen", "silinen", "yükseltilen", "düşürülen" veya "değişmeyen" olarak sınıflandırabilmelidir.
4. **FR-3.1:** Sistem; her paket sürümünü OSV.dev tavsiyeleriyle eşleştirmeli, CVE/GHSA/PYSEC gibi farklı kimlikleri aynı zafiyet altında birleştirebilmelidir.
5. **FR-4.1:** Sistem; paket lisans verilerini SPDX tanımlayıcılarına normalize edebilmeli ve çoklu ifadeleri (AND/OR/WITH) çözümleyebilmelidir.
6. **FR-4.2:** Sistem; çevrimdışı modda (offline) lisans verisi bulunmayan bir paket için ağ çağrısı yapmadan durumu UNKNOWN olarak raporlamalıdır.

7. **FR-5.1:** Sistem; npm ve PyPI ortamlarında eklenen paketler için en popüler 15.000 pakete göre Damerau-Levenshtein mesafesi (4 karakterden kısalar için 1, diğerleri için 2) hesaplayarak typosquatting taraması yapmalıdır.
8. **FR-5.2:** Sistem; kayıt defterlerinde var olmayan paket isimlerini "hallucinated/slopsquat" tespiti kapsamında işaretlemelidir.
9. **FR-6.1:** Sistem; "BLOCK" ve "WARN" eşik değerlerini, proje lisansını (project_license), dağıtım modunu (distribution_mode) ve "bastırma" (suppressions) kurallarını içeren bir YAML konfigürasyon dosyasını (policy) işlemelidir.
10. **FR-7.1:** Sistem; CLI ortamında 0 (kritik sorun yok), 1 (BLOCK eşiğine ulaşıldı) ve 2 (araç hatası) çıkış kodlarını (exit codes) başarılı bir şekilde üretebilmelidir.
11. **FR-8.1:** Sistem; GitHub Action olarak çalışırken her pull request'te mevcut rapor yorumunu (gizli işaretçi kullanarak) yerinde güncellemeli, çoklu yorum spam'ini engellemelidir.

2.2 Fonksiyonel Olmayan Gereksinimler (NFR)

1. **NFR-1 (Performans):** GitHub-hosted Linux sunucularında 1.000 paket içeren bir kilit dosyası taraması; çevrimiçi modda ve sıcak önbellekle maksimum 20 saniye, soğuk önbellekle maksimum 90 saniye sürmelidir.
2. **NFR-2 (Doğruluk - Accuracy):** Typosquatting tespiti hassasiyeti (precision) gizlenmiş test kümesinde en az 0.80 olmalı ve en popüler 15.000 paketteki yanlış pozitif (FPR) oranı maksimum %1 olarak gerçekleşmelidir.
3. **NFR-3 (Çalıştırma Güvenliği):** Araç yalnızca meta verileri okumalıdır; hiçbir paketin kodunu indirmemeli, kurulum scriptlerini çalıştırmamalı veya projeye ait kodları içe aktarmamalıdır.
4. **NFR-4 (Belirlenimcilik - Determinism):** Aynı girdiler ve aynı OSV veri tabanı anlık görüntüsü kullanıldığında araç istisnasız olarak her zaman aynı JSON çıktısını üretmelidir.
5. **NFR-5 (Gizlilik - Privacy):** Çevrimiçi modda, kamu API'lerine yalnızca ekosistem, paket adı ve paket sürümü bilgileri gönderilmelidir; kaynak kodları, repo meta verileri veya erişim token'ları makine dışına kesinlikle çıkmamalıdır.

2.3 Dokümana Özel Görev Matrisi (Requirements Document)

Görev	Sorumlu	Neden (Rationale) Assignment-1.pdf
Fonksiyonel Gereksinimler (FR 1-11) Çıkarımı	Ömer Ali Sarıcalar	Requirements Lead olarak kullanıcı ve sistem etkileşimlerinin teknik dokümantasyonunu yazmaya en uygun kişidir.
Fonksiyonel Olmayan Gereksinimler (NFR) Yazımı	Yusuf Emir Coşar	QA Lead rolüyle performans, doğruluk ve güvenlik ölçümlerinin test edilebilir şekilde ifade edilmesini sağlar.
Belge Son İncelemesi ve Formatlama	Ömer Ali Sarıcalar	Doküman bütünlüğünü ve test edilebilirliği güvence altına almak için.